# Threat Intelligence Report: Cross-Platform Vulnerability Landscape, OS Build Analysis, and Remediation Strategy (Q1 2026)

The global cybersecurity threat landscape in the first quarter of 2026 is characterized by a compounding crisis of aging infrastructure, the rapid weaponization of zero-day vulnerabilities, and the exploitation of deep-seated architectural flaws within core operating system kernels. As critical operating systems such as CentOS 7, Windows 10, and Windows Server 2012 R2 cross their end-of-life (EOL) or end-of-support (EOS) thresholds, organizations that have failed to secure Extended Security Updates (ESU) or Extended Life Cycle Support (ELS) find themselves exposed to an unforgiving exploitation environment. Concurrently, threat actors are shifting their focus toward foundational network protocols, embedded kernel modules, and the orchestration layers of machine learning pipelines, actively bypassing traditional perimeter defenses.

This threat intelligence report provides an exhaustive analysis of the current vulnerability ecosystem, directly addressing a specific inventory of critical operating system builds spanning enterprise Linux, Oracle Solaris, and the Microsoft Windows client and server ecosystems. It synthesizes recent patching cycles—specifically the March 2026 updates—while offering deep architectural insights into the most critical Common Vulnerabilities and Exposures (CVEs) currently under active exploitation. The analysis aims to equip enterprise security operations centers, infrastructure architects, and risk management executives with the actionable intelligence required to prioritize patching, implement compensating controls, and navigate the treacherous transition away from legacy operating systems.

## The Strategic Implications of Operating System End-of-Life and Build Fragmentation

The transition of an operating system into an unsupported state fundamentally alters the risk calculus of an enterprise environment. When vendors cease the distribution of regular security updates, vulnerabilities discovered in subsequent iterations of the software or shared underlying codebases can be effortlessly reverse-engineered by threat actors to attack legacy systems. This phenomenon creates a permanent and growing attack surface that cannot be mitigated by standard patch management procedures. The specific inventory under review highlights a severe fragmentation of operating system builds, ranging from critically obsolete kernels to the most recent enterprise releases.

### The Enterprise Linux Ecosystem: From Legacy to Modern Kernels

The Linux landscape is heavily defined by the kernel version in deployment, as the kernel dictates the capabilities of the networking stack, memory management, and container isolation

mechanisms. The inventory indicates the presence of Red Hat Enterprise Linux (RHEL) 6 operating on the 2.6.32 kernel, alongside CentOS 7 and RHEL 7 instances operating on the 3.10.0 kernel.

The presence of RHEL 6 (kernel 2.6.32) in any production capacity represents a catastrophic security risk. This operating system is entirely out of scope for any standard or extended support, meaning it is critically vulnerable to years of unpatched flaws, including severe memory corruption and local privilege escalation vectors. The architectural limitations of the 2.6.32 kernel prevent the implementation of modern exploit mitigations, rendering these systems indefensible against contemporary threat actors.

CentOS Linux 7 reached its definitive end-of-life on June 30, 2024. Unlike previous transitions, the CentOS Project—under the direction of Red Hat—shifted its focus entirely to CentOS Stream, eliminating the downstream, production-ready clone of Red Hat Enterprise Linux that countless enterprises relied upon for cost-effective server deployments. The termination of CentOS 7 means that the operating system no longer receives security patches, bug fixes, or performance enhancements, freezing the system in its last known state, typically kernel version 3.10.0-1160.119.1.

Simultaneously, Red Hat Enterprise Linux 7 reached the end of its Maintenance Support 2 phase on the same date, June 30, 2024. For RHEL 7, however, Red Hat offers an Extended Life Cycle Support (ELS) add-on, which provides up to four additional years of maintenance support—lasting until May 31, 2029. This ELS program delivers critical-impact security fixes and selected urgent-priority bug fixes for the final minor release, RHEL 7.9, incrementally updating the 3.10.0 kernel to versions such as 3.10.0-1160.146.1. The strategic implication here is a bifurcation of the ecosystem: organizations willing to invest in ELS maintain a secure, albeit aging, infrastructure, while those running CentOS 7 or un-extended RHEL 7 are highly vulnerable to unauthorized remote access, privilege escalation, and container escape attacks.

The inventory also notes the presence of modern enterprise Linux iterations, specifically Oracle Linux 8 (running Unbreakable Enterprise Kernels 5.4.17 and 5.15.0), RHEL 8 (kernel 4.18.0), and RHEL 9 (kernel 5.14.0). While these systems are actively supported, they represent the primary target for advanced persistent threats seeking to compromise modern cloud infrastructure. The open-source Linux kernel remains the foundational layer of modern computing, and consequently, it has accumulated the highest number of distinct vulnerabilities of any product into early 2026. Threat actors heavily target these kernels due to the immense complexity of their networking and memory management subsystems, which are universally deployed across global data centers.

## Table 1: Threat Intelligence Matrix - Enterprise Linux and Unix Operating Systems

The following matrix maps the specific Linux and Unix operating system versions and builds to their current vulnerability risk profiles, the top active CVEs affecting their respective ecosystems, and the required strategic resolution.

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| **Red Hat Enterprise 6** (Kernel 2.6.32 / 3.10.0) | **CRITICAL (Obsolete):** Complete loss of vendor support. Extreme risk of remote | 1. CVE-2021-22555 (Netfilter) 2. CVE-2017-1000253 (PIE bypass) 3. | **Immediate Migration Required:** Systems must be physically or logically isolated from |

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| | code execution, local privilege escalation, and complete infrastructure compromise. | CVE-2007-6283 (Bind) 4. CVE-2026-25749 (Vim OOB) 5. CVE-2016-5195 (Dirty COW) 6. CVE-2014-0160 (Heartbleed) 7. CVE-2019-11477 (SACK Panic) 8. CVE-2021-4034 (PwnKit) 9. CVE-2015-0235 (GHOST) 10. CVE-2022-0847 (Dirty Pipe) | all network traffic until migrated to RHEL 8/9. No patches available. |
| **CentOS 7** (Kernel 3.10.0) | **CRITICAL (EOL):** End of life as of June 30, 2024. No further security updates. High risk of exploitation via unpatched network subsystems. | 1. CVE-2024-1086 (nf_tables) 2. CVE-2025-38352 (POSIX timer) 3. CVE-2024-42256 (RCE) 4. CVE-2023-52814 (LPE) 5. CVE-2024-6387 (RegreSSHion) 6. CVE-2025-3498 (REST API) 7. CVE-2025-27028 (FS Read) 8. CVE-2024-43090 (XSS Info) 9. CVE-2023-49606 (UAF) 10. CVE-2022-24121 (SQLi) | **Migration or Third-Party ELS:** Utilize the ELevate utility to migrate in-place to AlmaLinux 8 or Rocky Linux 8, or purchase third-party Endless Lifecycle Support (e.g., TuxCare). |
| **Red Hat Enterprise 7** (Kernel 3.10.0 / 4.18.0) | **HIGH (EOS/ELS):** Maintenance Support 2 ended June 2024. Requires active Extended Life Cycle Support (ELS) subscription to receive critical updates. | 1. CVE-2024-1086 (nf_tables) 2. CVE-2025-38352 (POSIX timer) 3. CVE-2025-71085 (Kernel) 4. CVE-2024-57980 (uvcvideo) 5. CVE-2025-21928 (intel-ish-hid) 6. CVE-2025-23150 (ext4) | **Procure ELS:** Ensure ELS licensing is active to receive updates through May 2029. Apply RHSA-2025:14748 to update kernel to secure 3.10.0 branch. |

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| | | 7. CVE-2022-49788 (vmw_vmci) 8. CVE-2025-13601 (glib2) 9. CVE-2025-58098 (httpd) 10. CVE-2026-21925 (OpenJDK) | |
| **Oracle Linux Release 8** (Kernels 5.15.0 / 5.4.17) | **HIGH:** Active exploitation of UEK kernel subsystems. High risk of container escapes and memory corruption via eBPF and Netfilter. | 1. CVE-2025-40022 (Kernel) 2. CVE-2025-40021 (Kernel) 3. CVE-2025-40167 (Kernel) 4. CVE-2025-40183 (Kernel) 5. CVE-2025-40277 (Kernel) 6. CVE-2025-40215 (Kernel) 7. CVE-2021-4155 (eBPF leak) 8. CVE-2022-21505 (Lockdown) 9. CVE-2026-21992 (OIM) 10. CVE-2025-61884 (Oracle) | **Apply Kernel Errata:** Update to UEK R7 latest release (5.15.0-317.197.5.1) or UEK R6 patched release. Apply Oracle Linux Security Advisories for EL8 (e.g., ELISA-2026-3083). |
| **Red Hat Enterprise 8** (Kernel 4.18.0) | **HIGH:** Primary target for advanced persistent threats. Vulnerable to sophisticated memory manipulation and subsystem race conditions. | 1. CVE-2024-1086 (nf_tables) 2. CVE-2026-33750 (brace-exp) 3. CVE-2026-33748 (BuildKit) 4. CVE-2024-5042 (Submariner) 5. CVE-2025-7195 (Operator-SDK) 6. CVE-2024-1394 (Golang RSA) 7. CVE-2025-21756 (vsock UAF) 8. CVE-2025-38236 (UNIX Sockets) 9. CVE-2024-46689 (soc cmd-db) 10. | **Apply RHSA Updates:** Implement RHSA-2026:5197 and related kernel errata. Monitor for nf_tables exploitation. Ensure OpenShift operator permissions are restricted. |

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| | | CVE-2024-47679 (vfs race) | |
| **Red Hat Enterprise 9** (Kernel 5.14.0) | **HIGH:** Modern deployment target. Subject to identical kernel subsystem flaws as RHEL 8, specifically targeting cloud orchestration layers. | 1. CVE-2024-1086 (nf_tables) 2. CVE-2024-6387 (RegreSSHion) 3. CVE-2026-21968 (MySQL 8.4) 4. CVE-2026-21936 (MySQL 8.4) 5. CVE-2026-21937 (MySQL 8.4) 6. CVE-2025-38248 (Kernel) 7. CVE-2024-47727 (x86/tdx) 8. CVE-2024-49864 (rxrpc) 9. CVE-2024-50060 (io_uring) 10. CVE-2026-33872 (Ielixir) | **Apply RHSA Updates:** Apply kernel updates mitigating io_uring and rxrpc race conditions (RHSA-2025:20518). Update OpenSSH to mitigate RegreSSHion. |
| **Solaris 11** (Build 5.11.0) | **MEDIUM/HIGH:** Proprietary Unix environment vulnerable to embedded third-party library exploits and localized privilege escalation vectors. | 1. CVE-2025-21551 (Solaris DoS) 2. CVE-2026-21990 (VirtualBox) 3. CVE-2025-53070 (Availability) 4. CVE-2024-56337 (Oracle Comm) 5. CVE-2025-24813 (Tomcat RCE) 6. CVE-2024-52046 (Oracle Comm) 7. CVE-2026-21941 (MySQL) 8. CVE-2024-21287 (Agile PLM) 9. CVE-2025-49795 (Third Party) 10. OpenSSL 3.0.x vulnerabilities | **Apply SRU 91:** Install Solaris 11.4 Support Repository Update (SRU) 91 (March 2026) to update MySQL and OpenSSL. Utilize useradd -N to restrict uninitialized account access. |

## The Microsoft Client Ecosystem: Windows 10 and Windows 11 Build Analysis

The Microsoft client ecosystem is currently in a state of rapid transition, defined by the aggressive deprecation of older feature builds and the initiation of Extended Security Updates for the Windows 10 platform. The inventory lists specific builds of Windows 10 (19042 and 19045) and Windows 11 (22000, 22621, 22631, and 26100), each carrying a distinct support lifecycle and vulnerability footprint.

Windows 10 Build 19042 correlates to version 20H2, which reached its end of updates significantly earlier than the broader operating system. Devices remaining on Build 19042 are highly vulnerable to localized exploitation, as they lack years of cumulative security patches. Conversely, Windows 10 Build 19045 represents version 22H2, the final supported version of the operating system. Windows 10 officially reached its end-of-support on October 14, 2025. The November 2025 Patch Tuesday marked the first Extended Security Update (ESU) release for the Windows 10 ecosystem, specifically requiring hosts to be upgraded to the 22H2 release (Build 19045) to qualify for continued security patches. For organizations with vast fleets of legacy endpoints, the logistical challenge of ensuring ESU enrollment is immense. Out-of-band updates have been required simply to address bugs preventing ESU registration, highlighting the friction inherent in extending the lifecycle of aging operating systems. An unpatched Windows 10 endpoint serves as the ideal beachhead for a threat actor, providing a localized environment to execute privilege escalation attacks before moving laterally into the broader server infrastructure.

The Windows 11 inventory demonstrates the rapid cadence of Microsoft's Annual Channel releases. Build 22000 (version 21H2) and Build 22621 (version 22H2) have both reached the end of their mainstream support cycles for standard editions. Threat actors are keenly aware of update latency within enterprise environments and target these deprecated feature builds. Build 22631 (version 23H2) and Build 26100 (version 24H2) represent the currently supported general availability channels. However, even fully patched Windows 11 systems remain vulnerable to sophisticated exploitation. The March 2026 Patch Tuesday addressed numerous critical vulnerabilities across the Windows 11 landscape, including zero-click remote code execution vectors within the Microsoft Office suite that exploit the Windows Explorer Preview Pane. Furthermore, severe elevation of privilege vulnerabilities within the Windows Kernel (such as race conditions and use-after-free errors) continue to provide attackers with pathways to escalate from standard user access to full SYSTEM control.

## Table 2: Threat Intelligence Matrix - Microsoft Windows Client Operating Systems

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| **Windows 10 10.0** (Build 19042) | **CRITICAL (Obsolete):** Version 20H2. End of updates reached. Highly vulnerable to modern network and local privilege escalation vectors. | 1. CVE-2025-62215 (Kernel Race) 2. CVE-2024-38063 (IPv6 RCE) 3. CVE-2025-60724 (GDI+ RCE) 4. CVE-2026-26110 (Office RCE) 5. CVE-2026-26113 (Office RCE) 6. | **Force Upgrade:** Immediately deploy an in-place upgrade to Windows 10 Build 19045 (22H2) to qualify for ESU, or migrate to Windows 11. |

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| | | CVE-2026-25175 (NTLM EoP) 7. CVE-2025-24054 (NTLM Hash) 8. CVE-2026-26144 (Excel Info) 9. CVE-2026-23669 (Spooler RCE) 10. CVE-2026-24288 (Broadband) | |
| **Windows 10 10.0** (Build 19045) | **HIGH (ESU Required):** Version 22H2. Reached EOS October 2025. Requires active Extended Security Updates (ESU) licensing for patches. | 1. CVE-2026-26110 (Office RCE) 2. CVE-2026-26113 (Office RCE) 3. CVE-2025-62215 (Kernel Race) 4. CVE-2024-38063 (IPv6 RCE) 5. CVE-2026-26144 (Excel Info) 6. CVE-2025-60724 (GDI+ RCE) 7. CVE-2026-25185 (Shell Link) 8. CVE-2026-25175 (NTFS EoP) 9. CVE-2026-23669 (Spooler RCE) 10. CVE-2026-24294 (SMB Server) | **Enroll in ESU:** Ensure ESU enrollment. Apply March 2026 update KB5078885. Monitor for registry and kernel manipulation. |
| **Windows 11 10.0** (Build 22000) | **HIGH (EOS):** Version 21H2. Mainstream support ended. Vulnerable to newly discovered kernel and application flaws not backported. | 1. CVE-2025-62215 (Kernel Race) 2. CVE-2024-38063 (IPv6 RCE) 3. CVE-2026-26110 (Office RCE) 4. CVE-2026-26113 (Office RCE) 5. CVE-2026-26144 (Excel Info) 6. CVE-2026-21536 (Pricing RCE) 7. CVE-2026-26127 (.NET DoS) 8. CVE-2026-25173 | **Force Upgrade:** Update via feature enablement package to Build 22631 (23H2) or Build 26100 (24H2) to restore update compliance. |

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| | | (RRAS RCE) 9. CVE-2026-25185 (Shell Link) 10. CVE-2026-24294 (SMB Server) | |
| **Windows 11 10.0** (Build 22621) | **HIGH (EOS):** Version 22H2. End of updates for standard editions. Enterprise/Education support concluding. | 1. CVE-2025-62215 (Kernel Race) 2. CVE-2026-26110 (Office RCE) 3. CVE-2026-26113 (Office RCE) 4. CVE-2026-21536 (Pricing RCE) 5. CVE-2026-26125 (Payment EoP) 6. CVE-2026-26144 (Excel Info) 7. CVE-2026-25173 (RRAS RCE) 8. CVE-2026-26128 (SMB EoP) 9. CVE-2026-25165 (Perf Count) 10. CVE-2026-24290 (Proj File) | **Force Upgrade:** Deploy enablement package to transition to Build 22631 (23H2) immediately. Apply final applicable cumulative updates. |
| **Windows 11 10.0** (Build 22631) | **HIGH:** Version 23H2. Currently supported. Subject to continuous targeting via memory corruption and protocol spoofing. | 1. CVE-2026-26110 (Office RCE) 2. CVE-2026-26113 (Office RCE) 3. CVE-2026-21536 (Pricing RCE) 4. CVE-2026-26125 (Payment EoP) 5. CVE-2026-26144 (Excel Info) 6. CVE-2026-26127 (.NET DoS) 7. CVE-2025-62215 (Kernel Race) 8. CVE-2026-25173 (RRAS RCE) 9. CVE-2026-23669 (Spooler RCE) 10. CVE-2026-24288 (Broadband) | **Apply March 2026 Updates:** Install cumulative security update KB5078883. Disable Windows Explorer Preview Pane to mitigate zero-click Office RCEs. |

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| **Windows 11 10.0** (Build 26100) | **HIGH:** Version 24H2. Currently supported. Primary vector for advanced client-side exploitation and privilege escalation. | 1. CVE-2026-26110 (Office RCE) 2. CVE-2026-26113 (Office RCE) 3. CVE-2026-21536 (Pricing RCE) 4. CVE-2026-26125 (Payment EoP) 5. CVE-2026-26144 (Excel Info) 6. CVE-2026-26127 (.NET DoS) 7. CVE-2026-25175 (NTFS EoP) 8. CVE-2026-25185 (Shell Link) 9. CVE-2026-24294 (SMB Server) 10. CVE-2026-23669 (Spooler RCE) | **Apply March 2026 Updates:** Install cumulative security update KB5079473. Ensure Microsoft Defender Exploit Guard is fully configured. |

## Microsoft Windows Server Infrastructure and Core Service Vulnerabilities

The Windows Server infrastructure forms the backbone of enterprise identity, directory services, and internal routing. The provided inventory spans from the highly deprecated Windows Server 2012 R2 up to the cutting-edge Windows Server 2025. This vast age disparity creates significant challenges in maintaining a unified security posture, as foundational protocols behave differently across iterations.

Windows Server 2012 R2 (Build 9600) reached its end-of-support on October 10, 2023. To accommodate enterprises unable to migrate to modern equivalents, Microsoft initiated an Extended Security Updates (ESU) program, renewable annually until October 13, 2026. Systems enrolled in the ESU program continue to receive critical monthly rollups, such as the March 10, 2026, security update (KB5078774) which addresses severe vulnerabilities like the Internet Explorer 11 cumulative security update and essential servicing stack modifications. However, the reality of ESU deployment is often fragmented. The analysis indicates that threat actors heavily target Server 2012 R2 instances during the administrative gap between the expiration of standard support and the procurement of ESU licenses. Vulnerabilities such as CVE-2024-49112—a highly critical Windows LDAP Remote Code Execution flaw—pose existential threats to unpatched Server 2012 R2 domain controllers and member servers.

The Long-Term Servicing Channel (LTSC) and Long-Term Servicing Branch (LTSB) releases present in the inventory, specifically Windows Server 2016 (Build 14393) and Windows Server 2019 (Build 17763), are actively supported but frequently neglected due to their perceived stability. These systems, alongside the modern Windows Server 2022 (Build 20348) and Windows Server 2025 (Build 26100), are currently facing severe exploitation campaigns targeting default protocols. For instance, CVE-2024-38063 exploits the Windows TCP/IP stack

via malicious IPv6 extension headers, affecting all Windows Server editions from 2008 through 2022. Because the vulnerability resides at the network layer, an unauthenticated remote attacker can execute arbitrary malicious code with SYSTEM-level privileges before the traffic is ever inspected by higher-level application firewalls. Furthermore, the March 2026 update cycle revealed severe vulnerabilities within SQL Server deployments, specifically CVE-2026-21262, which allows an authorized attacker to elevate privileges over the network to full SQL sysadmin status.

## Table 3: Threat Intelligence Matrix - Microsoft Windows Server Operating Systems

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| **Windows Server 2012 R2** 6.3 (Build 9600) | **CRITICAL (EOS):** Reached EOS October 2023. Requires ESU. Prime target for Active Directory compromise, LDAP exploitation, and NTLM reflection. | 1. CVE-2024-49112 (LDAP RCE) 2. CVE-2024-38063 (IPv6 RCE) 3. CVE-2024-49124 (LDAP EoP) 4. CVE-2025-33073 (SMB NTLM) 5. CVE-2024-49079 (IME RCE) 6. CVE-2024-49090 (CLFS EoP) 7. CVE-2024-38140 (Kernel) 8. CVE-2024-38199 (Line Printer) 9. CVE-2024-38213 (SmartScreen) 10. CVE-2026-26127 (.NET DoS) | **Enroll in ESU:** Ensure ESU licensing is active. Apply March 2026 Security Monthly Quality Rollup (KB5078774) and SSU (KB5079233). Disable IPv6 if unused. |
| **Windows Server 2016** 10.0 (Build 14393) | **HIGH:** LTSB release. Vulnerable to deep protocol abuse including IP routing, remote access, and credential relay attacks. | 1. CVE-2024-49112 (LDAP RCE) 2. CVE-2024-38063 (IPv6 RCE) 3. CVE-2025-33073 (SMB NTLM) 4. CVE-2026-26127 (.NET DoS) 5. CVE-2026-21262 (SQL Server) 6. CVE-2024-38159 (Network) 7. CVE-2024-38160 (Network) 8. | **Apply March 2026 Updates:** Apply cumulative updates via WSUS. Enforce strict SMB signing across all member servers to mitigate CVE-2025-33073. |

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| | | CVE-2026-25173 (RRAS RCE) 9. CVE-2026-24294 (SMB Server) 10. CVE-2026-26115 (SQL Server) | |
| **Windows Server 2019** 10.0 (Build 17763) & version 1809 | **HIGH:** LTSC release. Significant exposure to orchestration layer attacks, Hyper-V escapes, and Active Directory component exploitation. | 1. CVE-2024-49112 (LDAP RCE) 2. CVE-2024-38063 (IPv6 RCE) 3. CVE-2025-33073 (SMB NTLM) 4. CVE-2026-21262 (SQL Server) 5. CVE-2026-25173 (RRAS RCE) 6. CVE-2026-26127 (.NET DoS) 7. CVE-2026-26128 (SMB EoP) 8. CVE-2026-25165 (Perf Count) 9. CVE-2025-24050 (Hyper-V) 10. CVE-2025-24072 (LSA EoP) | **Apply March 2026 Updates:** Install the latest cumulative update (resolves to 17763.8511). Restrict RRAS and enforce LDAP channel binding. |
| **Windows Server 2022** 10.0 (Build 20348) | **HIGH:** LTSC release. Prime target for advanced persistent threats seeking to compromise modern infrastructure via zero-day vulnerabilities. | 1. CVE-2024-49112 (LDAP RCE) 2. CVE-2024-38063 (IPv6 RCE) 3. CVE-2025-33073 (SMB NTLM) 4. CVE-2026-21262 (SQL Server) 5. CVE-2026-21536 (Pricing RCE) 6. CVE-2026-26127 (.NET DoS) 7. CVE-2026-25173 (RRAS RCE) 8. CVE-2026-24294 (SMB Server) 9. CVE-2026-26125 (Payment) 10. CVE-2026-23673 | **Apply March 2026 Updates:** Install cumulative security update KB5078766. Segment SQL Server environments and monitor for credential dumping. |

| OS Version & Build | Vulnerability Risk / Impact | Top 10 CVEs Affected | Patch / Resolution Strategy |
|---|---|---|---|
| | | (ReFS EoP) | |
| **Windows Server 2025** 10.0 (Build 26100) | **HIGH:** Current LTSC release. Actively targeted by novel exploit techniques focusing on virtualization, containers, and core OS services. | 1. CVE-2026-21536 (Pricing RCE) 2. CVE-2026-21262 (SQL Server) 3. CVE-2026-26127 (.NET DoS) 4. CVE-2026-26125 (Payment) 5. CVE-2026-25173 (RRAS RCE) 6. CVE-2026-26124 (Confidential) 7. CVE-2026-23651 (Confidential) 8. CVE-2026-24294 (SMB Server) 9. CVE-2026-25175 (NTFS EoP) 10. CVE-2026-23672 (UDFS EoP) | **Apply March 2026 Updates:** Install Hotpatch/Cumulative Update KB5078740. Restrict exposure of the Payment Orchestrator Service and RRAS. |

# Deep Dive: Critical Vulnerability Mechanics and Architectural Flaws

To effectively remediate the vulnerabilities identified within the tabular data, it is imperative to understand the underlying mechanics of how these flaws are exploited in the wild. The threat landscape in early 2026 has shifted significantly away from simple application-layer phishing toward the weaponization of foundational networking protocols, identity management systems, and kernel memory structures.

## The Weaponization of the Windows TCP/IP Stack (CVE-2024-38063)

One of the most profound architectural vulnerabilities affecting the Windows operating system is CVE-2024-38063, a critical Remote Code Execution flaw in the Windows TCP/IP stack carrying a maximum CVSS base score of 9.8. This vulnerability represents a fundamental failure in how the operating system handles deep network traffic, specifically targeting the processing of IPv6 extension headers. IPv6 was designed to address the exhaustion of the IPv4 address space and introduced modularity and flexibility through extension headers. These headers, positioned between the primary IPv6 header and the data payload, support optional network data and advanced routing features, such as the Hop-by-Hop Options (Next Header = 0) and Routing Header.

Because IPv6 is enabled by default on virtually all modern Windows systems—including the entire spectrum of Windows 10, Windows 11, and Windows Server iterations from 2008 through 2025—the attack surface is immense. The exploitation mechanism relies on an integer

underflow vulnerability triggered when the Windows TCP/IP stack processes a maliciously crafted sequence of IPv6 packets containing specific, malformed extension headers. The integer underflow leads to a memory corruption condition within the kernel space, allowing an unauthenticated remote attacker to execute arbitrary malicious code with SYSTEM-level privileges.

The third-order implication of CVE-2024-38063 is the exposure of the "dark protocol" space within enterprise networks. Many enterprise network security architectures, including traditional firewalls and intrusion detection systems (IDS), remain heavily optimized for IPv4 traffic inspection, treating IPv6 as an afterthought or an unmonitored default configuration. Because the vulnerability resides at the lowest levels of the network layer, the malicious packets are processed and the payload executed before the traffic is ever inspected by higher-level application firewalls or endpoint detection and response (EDR) agents operating in user space. Threat actors are acutely aware of this visibility gap. Organizations that are unable to immediately apply the necessary cumulative updates to their Windows server and client fleets are strongly advised to disable IPv6 entirely on internal network adapters, provided that disabling the protocol does not disrupt critical internal routing dependencies.

## Lightweight Directory Access Protocol (LDAP) and Active Directory Compromise

Equally critical to the integrity of the Microsoft ecosystem is CVE-2024-49112, a Remote Code Execution vulnerability within the Windows Lightweight Directory Access Protocol (LDAP) service, assigned a CVSS base score of 9.8. Active Directory, the central identity management system for the vast majority of enterprise networks, relies implicitly on LDAP for querying, authenticating, and modifying directory services. The vulnerability allows an unauthenticated attacker to send a specially crafted set of LDAP calls to a vulnerable Domain Controller over the network. These malformed requests trigger an integer overflow or wraparound condition (CWE-190) during the parsing of the LDAP sequence, resulting in arbitrary code execution within the context of the LDAP service.

The strategic danger of CVE-2024-49112 lies not just in the initial execution, but in its potential for sophisticated vulnerability chaining. While code execution achieved solely through this specific CVE occurs within the elevated context of the LDAP service, it does not immediately grant full, unrestricted SYSTEM privileges. However, advanced threat intelligence indicates that this vulnerability is rarely exploited in isolation. Threat actors systematically chain this remote code execution flaw with contemporaneous privilege escalation vulnerabilities, such as CVE-2024-49124 and CVE-2024-49127, which were disclosed concurrently by Microsoft. When these exploits are combined into a single, automated payload sequence, an attacker can establish an initial foothold on the Domain Controller via the LDAP service context, and then immediately escalate their privileges to full SYSTEM-level access. This results in the total cryptographic and administrative compromise of the Active Directory forest, allowing the attacker to extract the NTDS.dit database, forge Kerberos tickets (Golden Ticket attacks), and deploy enterprise-wide ransomware. This attack vector entirely bypasses traditional authentication perimeters and underscores the absolute necessity of aggressive patch management for all domain controllers, particularly those operating on legacy operating systems like Windows Server 2012 R2 that require specialized ESU licenses.

## NTLM Reflection and the Defeat of SMB Signing (CVE-2025-33073)

The evolution of credential relay attacks represents another critical threat vector that fundamentally challenges long-standing assumptions regarding internal network security. For over a decade, enabling Server Message Block (SMB) signing on Active Directory domain controllers has been a mandatory hardening practice, effectively preventing attackers from relaying intercepted NTLM authentication traffic directly against the DC to achieve administrative access. While this hardening created a robust defense for the core identity infrastructure, it concurrently generated a false sense of security regarding the broader network environment. Workstations and standard member servers, however, historically do not enforce SMB signing by default due to perceived performance overheads during large file transfers and compatibility concerns with legacy applications and non-Windows storage appliances.

This long-accepted gap in the security posture was catastrophically exploited by the discovery and weaponization of CVE-2025-33073. This vulnerability resurrects NTLM reflection—an attack class widely believed to have been mitigated by Microsoft security updates years prior—by discovering a novel bypass mechanism. By abusing how the Windows operating system handles marshaled target information within Domain Name System (DNS) records, an attacker can trick the SMB client into triggering local NTLM authentication. The result is devastating: authenticated remote code execution as SYSTEM on any domain-joined machine that does not strictly enforce SMB signing.

The most alarming aspect of CVE-2025-33073 is that it completely removes the prerequisite of administrative access for lateral movement. The only prerequisites for exploitation are basic network connectivity and standard, unprivileged credentials for any valid domain user. This vulnerability immediately invalidates traditional tiered administrative models that rely solely on logical isolation and restrictive group memberships. Threat actors can utilize this "one-hop problem" to instantly escalate from a compromised low-privileged workstation to SYSTEM access on adjacent servers. Once SYSTEM access is achieved on a member server, the attacker can harvest cached credentials, extract high-value data, or pave the path toward a DCSync attack and full domain replication if any legacy domain controller is found operating without SMB signing actively enforced.

## Linux Kernel Memory Management and Subsystem Exploitation

The vulnerability landscape for enterprise Linux distributions—including CentOS, RHEL, and Oracle Linux—is currently dominated by memory corruption flaws within the kernel itself, specifically Use-After-Free (UAF) and Out-Of-Bounds (OOB) memory access conditions. These kernel-level flaws are highly prized by threat actors because they facilitate highly reliable local privilege escalation (LPE) and enable attackers to escape the confinement of Docker, Kubernetes, or LXC containers to compromise the underlying physical host.

CVE-2024-1086 serves as a paramount example of this sophisticated threat. Affecting major Linux distributions with kernel versions ranging from 3.15 up to 6.8-rc1—which broadly encompasses the native kernels of CentOS 7, RHEL 8, RHEL 9, and Oracle Linux 8—this vulnerability resides deeply within the netfilter: nf_tables component of the Linux kernel. The nf_tables subsystem is responsible for packet filtering, network address translation (NAT), and the underlying mechanics of modern Linux firewalls. A Use-After-Free error occurs when the kernel improperly mishandles memory allocation and deallocation during the processing of network traffic filtering rules.

Because the exploit complexity is remarkably low and exploit code is widely available, a standard unprivileged user—or, more commonly, a compromised service account operating within a limited container environment—can trigger the memory corruption to overwrite critical kernel structures. This manipulation forces the kernel to grant the executing process root administrator privileges. Once root access is secured, the attacker possesses the capability to permanently disable SELinux or AppArmor protections, deploy deeply hidden rootkits, manipulate core system files, and pivot across the internal network. While vendors like Red Hat and Oracle provided rapid kernel errata to mitigate the issue (such as kernel-4.18.0-147.el8 for RHEL 8), administrators running legacy, unpatched, or EOL systems are forced to rely on blacklisting the nf_tables kernel module. This operational workaround is highly disruptive, as it frequently breaks legitimate container networking overlays, pod-to-pod communication, and host-based firewall rules.

Furthermore, race conditions in time-sensitive kernel operations are emerging as a favored attack vector. CVE-2025-38352, a flaw actively tracked by CISA in its Known Exploited Vulnerabilities (KEV) catalog, involves a highly precise Time-of-Check to Time-of-Use (TOCTOU) race condition within the Linux kernel's POSIX CPU timers subsystem. Specifically, the race condition occurs within a minute window between the execution of the handle_posix_cpu_timers() and posix_cpu_timer_del() functions. If an attacker can accurately time the execution of malicious syscalls during this window, the kernel is forced into a Use-After-Free state, yielding identical privilege escalation results as the nf_tables exploit. The virtualization layer is similarly under assault, evidenced by CVE-2025-21756, a Use-After-Free vulnerability in the Virtual Socket (vsock) subsystem that governs communication between virtual machines and their hypervisor hosts, potentially allowing guest-to-host escapes.

# The Orchestration Attack Surface: AI Frameworks and Edge Appliances

As traditional operating system perimeters harden through the deployment of EDR platforms and zero-trust architectures, sophisticated threat actors are maneuvering toward the orchestration layers of Artificial Intelligence (AI) and Machine Learning (ML) pipelines, as well as internet-facing edge appliances. These systems often lack mature security monitoring and represent massive, aggregated repositories of corporate data.

## Artificial Intelligence Infrastructure Vulnerabilities

The rapid integration of Large Language Models (LLMs) and generative AI into enterprise workflows has necessitated the deployment of complex orchestration platforms. These platforms act as the connective tissue between the proprietary AI model, external application programming interfaces (APIs), and internal corporate databases. Consequently, a compromise of the orchestrator yields unprecedented, unmonitored access to sensitive intellectual property and data lakes.

In March 2026, the Cybersecurity and Infrastructure Security Agency (CISA) added CVE-2026-33017 to the KEV catalog, highlighting a highly dangerous code injection vulnerability in the Langflow platform. Langflow is a widely adopted open-source, low-code interface used extensively for building multi-agent AI workflows and integrating LLMs into business applications. The vulnerability, carrying a CVSS base score of 9.8, enables an unauthenticated, remote attacker to bypass all standard access controls. The attacker can

construct public workflows and inject malicious scripts directly into the application interface without requiring any valid credentials.
The technical failure stems from a combination of improper control of generated code (CWE-94), improper evaluation of injected directives (CWE-95), and a complete lack of authentication for critical orchestration functions (CWE-306). The ripple effects of this exploitation are profound. Threat intelligence reports and telemetry from cloud security vendors indicate that attackers exploiting CVE-2026-33017 successfully extracted highly sensitive data from vulnerable Langflow instances. This stolen data included administrative API keys for cloud environments (AWS), OpenAI, and Anthropic. Using these stolen credentials, threat actors pivoted laterally to compromise connected vector databases, alter AI training data (model poisoning), and hijack auxiliary cloud services, transforming an application-layer vulnerability into a catastrophic, enterprise-wide breach.
Similarly, foundational AI training frameworks developed by NVIDIA have been explicitly targeted. In early 2026, NVIDIA was forced to issue emergency patches for CVE-2025-33244, a critical vulnerability affecting the NVIDIA Apex PyTorch extension, a tool heavily utilized for mixed-precision and distributed AI model training. Vulnerabilities within the Triton Inference Server and the Megatron LM framework also surfaced concurrently, exposing organizations to remote code execution and the potential theft of proprietary AI models during the highly sensitive training or inference phases.

### CISA Known Exploited Vulnerabilities (KEV) Trends

An analysis of the CISA KEV catalog additions in Q1 2026 reveals a stark acceleration in the weaponization of perimeter vulnerabilities and supply chain infrastructure. The KEV catalog, mandated by Binding Operational Directive (BOD) 22-01, requires Federal Civilian Executive Branch (FCEB) agencies to remediate identified vulnerabilities by strict deadlines, serving as the definitive global standard for prioritizing patch management.
In a single update on March 20, 2026, CISA added five actively exploited CVEs to the catalog, including devastating code injection flaws in Craft CMS (CVE-2025-32432) and Laravel Livewire (CVE-2025-54068), alongside multiple Apple memory corruption issues. A subsequent update on March 26, 2026, added CVE-2026-33634, an embedded malicious code vulnerability discovered within the Aqua Security Trivy container scanning engine.
The inclusion of an infrastructure security tool like Trivy into the KEV catalog highlights a terrifying meta-trend: attackers are intentionally targeting the security scanning and continuous integration/continuous deployment (CI/CD) pipelines of an organization. By compromising the very tools designed to detect malicious code, attackers can insert backdoors seamlessly into production container images before they are deployed to Kubernetes clusters, achieving immense supply chain leverage and establishing persistence that evades runtime detection.
Furthermore, perimeter firewall appliances continue to face relentless assault, with deserialization flaws in Cisco Secure Firewall Management Center (Cisco FMC) providing attackers with unauthenticated root access to the exact devices intended to defend the network boundary.

## Strategic Remediation and Defense-in-Depth Architecture

The convergence of zero-day exploits, legacy infrastructure decay, and the rapid expansion of

the orchestration attack surface requires a remediation strategy that transcends simple patch management. Organizations must abandon reactive patching in favor of a proactive defense-in-depth architecture that assumes a breach has occurred and prioritizes the mitigation of lateral movement.

## Navigating the Post-EOL Lifecycle and Legacy Systems

The most urgent structural risk facing enterprises is the persistence of obsolete operating systems, specifically CentOS 7, RHEL 6, Windows 10 (pre-22H2), and Windows Server 2012 R2. The financial reluctance or operational inability to initiate a full migration must be weighed against the actuarial reality of an unpatched, internet-facing server.

1. **Immediate Procurement of Extended Support:** For organizations incapable of executing an immediate, comprehensive migration, the procurement of vendor-supported extended lifecycles is absolutely non-negotiable. This includes purchasing the RHEL Extended Life Cycle Support (ELS) add-on to ensure coverage until 2029, enrolling legacy Windows Server 2012 R2 and eligible Windows 10 endpoints in the Microsoft Extended Security Updates (ESU) program, or utilizing third-party life extension services (such as TuxCare Endless Lifecycle Support) for orphaned CentOS 7 deployments. Without these legal and technical mechanisms, organizations will fundamentally lack the binary patches required to close kernel, LDAP, and TCP/IP vulnerabilities.
2. **In-Place Migrations and Enablement Packages:** For CentOS 7 users, utilizing tools like the ELevate utility provides a relatively frictionless pathway to migrate in-place to supported downstream RHEL derivatives like AlmaLinux 8 or Rocky Linux 8, bypassing the need for a highly disruptive architectural rebuild. Within the Microsoft ecosystem, administrators must aggressively deploy enablement packages to transition endpoints from unsupported Windows 11 builds (e.g., 22000, 22621) to the currently supported 23H2 or 24H2 feature branches.
3. **Isolation and Microsegmentation:** If a legacy asset cannot be patched or legally enrolled in an ESU/ELS program, it must be cryptographically and logically isolated from the broader enterprise environment. These assets must be removed from the primary Active Directory domain to prevent credential harvesting, placed in highly restricted VLANs, and forced to communicate solely through strict application-layer firewalls that inspect traffic for protocol abuse.

## Hardening the Network Protocol Attack Surface

The weaponization of foundational protocols (IPv6, LDAP, SMB) requires aggressive, enterprise-wide configuration management to neutralize the vectors utilized by the most critical CVEs.

1. **Disable Unused and Legacy Protocols:** The exploitation of CVE-2024-38063 clearly demonstrates the danger of dormant, unmonitored protocols. If an enterprise network relies exclusively on IPv4 routing architecture, IPv6 must be systematically disabled across all Windows network adapters via Group Policy (GPO). Furthermore, legacy authentication protocols such as NTLMv1 and outdated cryptographic ciphers must be universally disabled to force the use of modern Kerberos authentication.
2. **Enforce SMB Signing Universally:** To permanently neutralize the resurrection of NTLM relay attacks and NTLM reflection techniques (CVE-2025-33073), organizations must enforce SMB signing not only on Domain Controllers but across all member servers and

standard Windows workstations. While this may introduce marginal performance overhead during bulk data transfers, it is the only definitive method to prevent unauthenticated attackers from gaining SYSTEM privileges via reflected authentication.

3. **Restrict and Monitor LDAP:** To defend against CVE-2024-49112 and related directory service exploits, LDAP traffic should be strictly monitored for anomalous deserialization queries and unusually large payload sizes. LDAP signing and LDAP channel binding must be enforced on all Domain Controllers to prevent credential harvesting, manipulation, and the chaining of privilege escalation flaws.

## Securing the AI Orchestration Layer and Supply Chain

The rapid inclusion of Langflow (CVE-2026-33017) and CI/CD security infrastructure into the CISA KEV catalog signals a paradigm shift: threat actors now view AI orchestrators and DevOps pipelines as the ultimate pivot points.

1. **Strict Identity and Access Management (IAM):** AI frameworks, orchestration interfaces, and low-code platforms should never be exposed directly to the public internet. They must be placed behind robust, multi-factor authentication (MFA) gateways and Zero-Trust Network Access (ZTNA) proxies to prevent unauthenticated code injection attacks.
2. **Dynamic Credential Vaulting:** Hardcoding API keys (such as AWS access tokens, OpenAI credentials, or database connection strings) into the orchestrator interface or source code repositories is a catastrophic vulnerability. Orchestrators must integrate directly with dynamic secrets management vaults (e.g., HashiCorp Vault, CyberArk, Azure Key Vault). This ensures that if a code injection vulnerability is exploited, the extracted keys have minimal time-to-live (TTL) and restricted, least-privilege scopes, containing the blast radius of the breach.
3. **Supply Chain Integrity Verification:** The discovery of embedded malicious code in vulnerability scanners themselves (CVE-2026-33634 in Aqua Trivy) requires organizations to implement software bill of materials (SBOM) tracking. Security teams must independently verify the checksums and cryptographic signatures of their CI/CD and security tooling before deployment to ensure the integrity of the scanning pipeline.

The cyber threat landscape in the first quarter of 2026 demonstrates an environment where technical debt has immediate and severe consequences. The simultaneous expiration of support for pillar operating systems has created a target-rich environment for ransomware syndicates and advanced persistent threats. To maintain operational resilience, organizations must enforce stringent protocol hardening, secure extended support licensing, and apply zero-trust architectural principles to both traditional virtualization stacks and emerging machine learning pipelines.

### Works cited

1. CVE-2026-25749 - Red Hat Customer Portal, https://access.redhat.com/security/cve/cve-2026-25749 2. RHEL CVE Database : r/cybersecurity - Reddit, https://www.reddit.com/r/cybersecurity/comments/1obo4t7/rhel_cve_database/ 3. What CentOS EOL Means and How to Stay Secure After Support Ends - TuxCare, https://tuxcare.com/blog/centos-eol/ 4. What to know about CentOS Linux EOL - Red Hat, https://www.redhat.com/en/topics/linux/centos-linux-eol 5. 3.10.0-1160.119.1.el7 - KernelCare Patches,

https://patches.kernelcare.com/b58c87f385e55f153ba33f818a154db9ba27f39c/22/kpatch.html 6. What to know for Red Hat Enterprise Linux 7 End of Maintenance, https://www.redhat.com/en/technologies/linux-platforms/enterprise-linux/rhel-7-end-of-maintenance 7. AWS Marketplace: Red Hat Enterprise Linux (RHEL) 7 Extended Life Cycle Support (ELS) - Amazon.com, https://aws.amazon.com/marketplace/pp/prodview-msu54ql7u6grg 8. Supported Red Hat Enterprise Linux kernel versions 7 and earlier - Trellix Thrive Portal, https://thrive.trellix.com/s/article/KB93176 9. TOP-10 Linux Vulnerabilities in 2024 - AI EdgeLabs, https://edgelabs.ai/blog/top-10-linux-vulnerabilities-in-2024/ 10. CentOS 7 EOL: Your 2026 Migration & Support Guide - TuxCare, https://tuxcare.com/blog/what-does-the-end-of-life-of-centos-7-mean-a-breakdown-of-your-options/ 11. kernel-uek vulnerabilities | Snyk, https://security.snyk.io/package/linux/oracle%3A8/kernel-uek 12. Revision History for Oracle Linux STIG Images, https://docs.oracle.com/en-us/iaas/oracle-linux/oci/stig-revision-history.htm 13. Unbreakable Enterprise Kernel Release 7 - Release Notes (5.15.0-0.30), https://docs.oracle.com/cd/F10276_01/7/relnotes7.0/UEK-RELNOTES-7-0.pdf 14. Unpacking CVE-2024-1086: A Critical Linux Kernel Flaw | Immersive Community - 631, https://community.immersivelabs.com/blog/the-human-connection-blog/unpacking-cve-2024-1086-a-critical-linux-kernel-flaw/631 15. Vulnerabilities Statistics 2025: Record CVEs, Zero-Days & Exploits - DeepStrike, https://deepstrike.io/blog/vulnerability-statistics-2025 16. Windows 10 - release information - Microsoft Learn, https://learn.microsoft.com/en-us/windows/release-health/release-information 17. November 2025 Patch Tuesday: Updates and Analysis | CrowdStrike, https://www.crowdstrike.com/en-us/blog/patch-tuesday-analysis-november-2025/ 18. Critical Microsoft vulnerabilities November 2025 - Cibersafety, https://cibersafety.com/en/critical-Microsoft-vulnerabilities-November-2025/ 19. Windows 11 version history - Wikipedia, https://en.wikipedia.org/wiki/Windows_11_version_history 20. Cumulative Updates: March 10th, 2026 : r/Windows11 - Reddit, https://www.reddit.com/r/Windows11/comments/1rq3n60/cumulative_updates_march_10th_2026/ 21. Windows 11 - release information - Microsoft Learn, https://learn.microsoft.com/en-us/windows/release-health/windows11-release-information 22. March 2026 Patch Tuesday: Updates and Analysis | CrowdStrike, https://www.crowdstrike.com/en-us/blog/patch-tuesday-analysis-march-2026/ 23. Microsoft Patch Tuesday: March 2026 - Arctic Wolf, https://arcticwolf.com/resources/blog/microsoft-patch-tuesday-march-2026/ 24. Microsoft Patch Tuesday security updates for March 2026 fixed 84 bugs, https://securityaffairs.com/189266/security/microsoft-patch-tuesday-security-updates-for-march-2026-fixed-84-bugs.html 25. Microsoft Patch Tuesday, November 2025 Security Update Review - Qualys Blog, https://blog.qualys.com/vulnerabilities-threat-research/2025/11/11/microsoft-patch-tuesday-november-2025-security-update-review 26. Windows 11 CVEs and Security Vulnerabilities - OpenCVE, https://app.opencve.io/cve/?product=windows_11&vendor=microsoft 27. KB5079233: Servicing stack update for Windows Server 2012 R2: March 10, 2026, https://support.microsoft.com/en-us/topic/kb5079233-servicing-stack-update-for-windows-server-2012-r2-march-10-2026-22f06ce9-b566-4a8a-94f8-f8acc4cb9db5 28. March 10, 2026—KB5078774 (Monthly Rollup) - Microsoft Support, https://support.microsoft.com/en-us/topic/march-10-2026-kb5078774-monthly-rollup-caab8f62-1cac-4428-8147-dc1ca5e089d4 29. Patch Tuesday Updates: March 2026 - ManageEngine PitStop,

https://pitstop.manageengine.com/portal/en/community/topic/patch-tuesday-updates-march-2026 30. December 10, 2024—KB5048735 (Monthly Rollup) - Microsoft Support, https://support.microsoft.com/en-us/topic/december-10-2024-kb5048735-monthly-rollup-fecca566-c13b-4888-be89-38a810c0e477 31. Microsoft Patch Tuesday August 2024 - Arctic Wolf, https://arcticwolf.com/resources/blog/microsoft-patch-tuesday-august-2024/ 32. Microsoft Patch Tuesday: December 2024 - Arctic Wolf, https://arcticwolf.com/resources/blog/microsoft-patch-tuesday-december-2024/ 33. CVE-2024-49112 Detail - NVD, https://nvd.nist.gov/vuln/detail/cve-2024-49112 34. Windows Server release information | Microsoft Learn, https://learn.microsoft.com/en-us/windows/release-health/windows-server-release-info 35. March 10, 2026—KB5078766 (OS Build 20348.4893) - Microsoft Support, https://support.microsoft.com/en-us/topic/march-10-2026-kb5078766-os-build-20348-4893-fa3ee26a-0877-47d7-a4b2-9dd632ea8cea 36. CVE-2024-38063 – Windows TCP/IP Vulnerability Explained - OPSWAT, https://www.opswat.com/blog/comprehensive-breakdown-of-cve-2024-38063-a-critical-threat-in-the-windows-tcp-ip-stack 37. CVE-2024-38063: An In-Depth Look at the Critical Remote Code Execution Vulnerability, https://strobes.co/blog/cve-2024-38063-an-in-depth-look-at-the-critical-remote-code-execution-vulnerability/ 38. Microsoft IPv6 Remote Code Execution Vulnerability: Security Bulletins - Indiana University, https://informationsecurity.iu.edu/security-bulletins/bulletins-2024-08-14-remote-code-executon-windows-vuln.html 39. Microsoft March 2026 Patch Tuesday fixes 2 zero-days, 79 flaws - Bleeping Computer, https://www.bleepingcomputer.com/news/microsoft/microsoft-march-2026-patch-tuesday-fixes-2-zero-days-79-flaws/ 40. CVE-2024-49112 - CVE Record, https://www.cve.org/CVERecord?id=CVE-2024-49112 41. Advisory: Critical vulnerability in Windows LDAP (CVE-2024-49112) - Mnemonic, https://www.mnemonic.io/resources/blog/advisory-critical-vulnerability-in-windows-ldap-cve-2024-49112/ 42. Reflecting on Your Tier Model: CVE-2025-33073 and the One-Hop Problem, https://securityboulevard.com/2026/03/reflecting-on-your-tier-model-cve-2025-33073-and-the-one-hop-problem/ 43. The Most Critical Linux Kernel Breaches of 2025 So Far, https://www.linuxjournal.com/content/most-critical-linux-kernel-breaches-2025-so-far 44. Linux Kernel Vulnerabilities Exploited in 2025: CISA KEV Insights, https://linuxsecurity.com/news/security-vulnerabilities/7-linux-kernel-vulnerabilities-exploited-in-2025 45. CVE-2024-1086 Detail - NVD, https://nvd.nist.gov/vuln/detail/cve-2024-1086 46. CVE-2024-1086 - Red Hat Customer Portal, https://access.redhat.com/security/cve/cve-2024-1086 47. CVE-2024-1086 solution for RHEL - Linux.org, https://www.linux.org/threads/cve-2024-1086-solution-for-rhel.48556/ 48. CISA Warns of Langflow Code Injection Vulnerability Exploited in Attacks, https://cybersecuritynews.com/langflow-code-injection-vulnerability/ 49. Critical Flaw in Langflow AI Platform Under Attack, https://www.darkreading.com/vulnerabilities-threats/critical-flaw-langflow-ai-platform-under-attack 50. Critical NVIDIA Vulnerabilities Enables RCE and DoS Attacks, https://cybersecuritynews.com/nvidia-vulnerabilities-rce-attacks/ 51. CISA Adds One Known Exploited Vulnerability to Catalog, https://www.cisa.gov/news-events/alerts/2026/03/26/cisa-adds-one-known-exploited-vulnerability-catalog 52. CISA Adds Five Known Exploited Vulnerabilities to Catalog, https://www.cisa.gov/news-events/alerts/2026/03/20/cisa-adds-five-known-exploited-vulnerabiliti

es-catalog 53. Known Exploited Vulnerabilities Catalog | CISA, https://www.cisa.gov/known-exploited-vulnerabilities-catalog 54. Red Hat Enterprise Linux Extended Life Cycle Support - Azure Virtual Machines, https://learn.microsoft.com/en-us/azure/virtual-machines/workloads/redhat/redhat-extended-lifecycle-support